Data Classification and Retention Policy

Document ID	SEC-005
Department	IT and Information Security
Document type	Policy
Owner	Chief Information Security Officer
Version	3.0
Status	APPROVED
Effective / last reviewed	2026-02-06
Audience	All employees and contractors
Related documents	SEC-014, SEC-008, ENG-009, CS-007

Summary. Defines Northstar's four data classification levels (Public, Internal, Confidential, Restricted), handling rules for each, labelling, sharing, AI tool restrictions, and the retention schedule by record type including legal hold, destruction and disposal records.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This policy explains how Northstar Systems classifies information, how each class must be handled, and how long records must be kept before they are destroyed. It supports SEC-001 (Information Security Policy) and applies to all data owned, held or processed by Northstar, in any form, including customer data held in the Northstar Nexus Platform, Nexus Connect and Nexus Insight, employee data in NorthPeople and NorthPay, and corporate records in NorthBuy, NorthDesk and email. It applies to all employees, contractors and third parties.

Retention periods in this policy are business rules for Northstar. Statutory minimums, tax and labour law references, and privacy law references are illustrative and must be verified by Legal before external use. Where a longer legal or contractual period applies, the longer period governs.

2. Definitions

- **Data owner**: the department head accountable for a data set, who decides its classification and who may access it.
- **Data custodian**: the team that operates the systems storing the data, such as IT Operations or Data Engineering.
- **Personal data**: any information that identifies a living individual, such as name with phone number, bank account, address or government ID (illustrative; verify with Legal).
- **Legal hold**: a notice from the General Counsel that suspends deletion of specified records because of litigation, investigation or audit.
- **Retention period**: the minimum time a record must be kept.
- **Destruction record**: documentation that data was destroyed by an approved method, with date, method, scope and approver.
- **Approved tools**: the corporate platforms authorised for sharing a given class, such as NorthVault for credentials and the corporate file share.

- **External AI tool**: any AI service not on the Approved AI Tools list, or any service hosted outside Northstar's control.

3. Roles and Responsibilities

Role	Responsibility
CISO	Owns this policy, approves the classification scheme and the retention schedule
General Counsel	Issues and releases legal holds, advises on legal retention periods
Privacy Officer	Reviews personal-data classification and handles data subject requests and breach notifications
Data owners	Classify their data, approve access, and confirm retention periods
Data custodians	Apply technical controls, run deletion jobs, keep destruction records
All personnel	Label and handle information according to its class, never store it where it is not allowed

4. Classification Levels

Northstar uses four levels. When in doubt, choose the higher level and ask the data owner or the Security Desk.

Level	Meaning	Examples
Public	Approved for release to anyone	Published website content, press releases, public product documentation, marketing material
Internal	For employees and approved contractors; low harm if disclosed	Org charts, internal policies, meeting notes, general project plans
Confid ential	Disclosure would harm Northstar, a customer or a partner	Customer contracts, pricing and proposals, source code, architecture designs, vendor agreements, audit reports
Restrict ed	Highest sensitivity; disclosure could cause serious legal, financial or customer harm	Customer production data, personal data of employees, credentials, encryption keys, unreleased financials

4.1 How to classify

1 Identify the data owner.
2 Consider the worst realistic consequence of unauthorised disclosure, change or loss.
3 Apply the highest level that fits any part of the document.
4 Record the class in the document header, file name, folder or system tag.

Information aggregated from several sources takes the highest class of its components. A report that combines Internal sales figures with customer names and contract values becomes Confidential. A support export that contains customer production data is Restricted.

Example: A Customer Success Manager prepares a QBR deck that includes a customer's usage metrics, uptime history and open tickets. The deck is Confidential because it relates to a customer. If it includes a real customer record taken from the production environment, the attached sample is Restricted and must be removed.

5. Handling Rules by Classification

Control	Public	Internal	Confidential	Restricted
Labelling	Optional	Recommended	Required	Required
Storage	Anywhere approved	Corporate systems	Corporate systems with access control	Encrypted at rest on approved systems only
Transmission	Any	Corporate email or tools	Encrypted channels; TLS 1.2 minimum	Encrypted in transit and at rest; approved tools only
Sharing outside Northstar	Allowed	Needs manager approval	Needs data owner approval and an NDA	Needs data owner and CISO approval and a Data Processing Agreement where personal data
Personal email or messaging	Allowed	Not allowed	Not allowed	Never allowed
External AI tools	Allowed	Only if the tool is approved	Not allowed	Never allowed
Printing and paper	Allowed	Allowed	Collect immediately, lock away, shred	Avoid printing; if needed, shred after use
Disposal	Normal	Normal	Secure deletion or shredding	Certified destruction with a record

5.1 Restricted data rules

Restricted data must be encrypted at rest (AES-256) and in transit (TLS 1.2 minimum, TLS 1.3 preferred). It may be shared only through approved tools. It must never be placed in personal email, personal cloud storage, messaging applications or external AI tools. Access is limited to named individuals and reviewed every quarter under SEC-002. Restricted production data must not be copied into test environments; use masked or synthetic data. Credentials and keys must be held only in NorthVault, the cloud KMS or an HSM, as described in SEC-003.

5.2 Confidential data rules

Confidential data must be stored in corporate systems with role-based access. It may be emailed within Northstar but must not be sent to personal accounts. External sharing requires a signed NDA and the approval of the data owner. Source code is Confidential and must live only in the approved repositories.

5.3 Customer data

Customer production data held for support or operations is Restricted. Support staff may view it only through approved NorthAssist and platform tools, only for a ticket-linked reason, and must not export it. Customer-facing messages must contain no internal system names or personal data beyond what the customer already has. For customer data handling in the product, see ENG-009.

5.4 Personal data and privacy

Collect only the personal data that is necessary for a documented purpose. Employee personal data is Restricted. Data subject access requests are answered within 30 days. Correction and erasure requests are triaged by the Privacy Officer. Any suspected personal-data breach must be reported to the Privacy Officer at once through the Security Desk. A Data Protection Impact Assessment is needed for new high-risk processing, and processors must be bound by a Data Processing Agreement (illustrative; verify with Legal).

5.5 Labelling and sharing in practice

Documents carry their class in the header or footer, for example "Confidential - Northstar Systems". Files containing Restricted data must also carry the class in the file name or folder, so that data loss prevention rules and reviewers can recognise them. Messages in chat tools may not contain Restricted data, even in private channels. Meeting recordings that include Confidential discussion must be stored only in the corporate file share and shared by link with named participants, never as a public link.

Before sharing any file outside Northstar, the sender must answer four questions: what is the class, who owns it, is there an NDA or Data Processing Agreement in place, and is the recipient channel approved. If any answer is unknown, the sender must stop and ask the data owner or the Security Desk.

Example 1: A Sales Director wants to send a customer a proposal with pricing. Pricing is Confidential, so the Director confirms an NDA exists, sends the file through the corporate file share with a link limited to the named recipients and an expiry, and does not use personal email.

Example 2: A Data Engineer is asked to debug a Pipeline issue using real customer records. The records are Restricted. He must work only within the approved production tooling, or use masked or synthetic data in the test environment, and must not download the records to a laptop or paste them into an external AI tool.

Example 3: A recruiter wants to keep the CVs of unsuccessful candidates for two years in case a role opens. This is not allowed, because the retention period for such records is 12 months. If the candidate consents, the recruiter may keep the CV in the talent pool with a recorded consent, which is reviewed each year, otherwise the record is deleted after 12 months.

5.6 Data inventory and ownership reviews

Every department head, as data owner, keeps a register of the data sets they own, with the class, the system, the custodian and the retention period. The register is reviewed every year by the CISO's office. New data sets must be added when a new system, integration or vendor is introduced, and the owner must confirm the class before go-live. Orphan data with no owner is treated as Confidential until an owner is assigned, and the Security team escalates it to the department head within 10 business days.

6. Retention Schedule

The following minimum retention periods apply. Systems of record must keep the data for the full period, and custodians must delete it when the period ends unless a legal hold applies.

Record type	Retention period
Customer contracts	8 years after expiry
Financial and tax records	8 years
Payroll records	8 years
Employee records	7 years after exit
Support tickets	5 years after closure
Email	3 years
Application logs	12 months

Record type	Retention period
Security audit logs	24 months
Recruitment records of unsuccessful candidates	12 months
CCTV footage	30 days
Backups	As set in ENG-014

Notes on the schedule:

1 The retention clock starts at the event that is named in the table: expiry for contracts, exit for employee records and ticket closure for support tickets. Financial and payroll records count from the end of the fiscal year in which they were created.
2 Observability data has its own technical retention. Logs are kept 30 days hot and 12 months archived, which is why application logs are held for 12 months.
3 Security audit logs are kept for 24 months in tamper-evident storage, and forensic evidence for a security incident is preserved for 12 months.
4 Personal data must not be kept longer than the retention period just because storage is cheap.

Example: An employee leaves Northstar on 30 June 2026. The employee record must be retained until 30 June 2033, which is 7 years after exit. The payroll records from the final year are kept for 8 years from the end of the fiscal year in which they were created, which is until 31 March 2035 for payroll created in FY 2026-27. The recruitment file of an unsuccessful candidate who interviewed on 10 January 2026 is deleted after 12 months, on 10 January 2027.

Example: A customer contract expires on 31 March 2026. The contract is retained until 31 March 2034. A support ticket closed on 15 September 2026 is retained until 15 September 2031.

6.1 Applying the schedule in systems

Data custodians configure each system of record to enforce the schedule. NorthPeople and NorthPay hold employee and payroll records, NorthAssist holds support tickets, and NorthBuy holds contracts. Deletion jobs run quarterly, produce a list of records due for deletion, and need the data owner's confirmation before they run. Records subject to a legal hold are excluded automatically. The custodian files the destruction record in NorthDesk after each run.

7. Legal Hold

The General Counsel issues a legal hold when litigation, regulatory inquiry or audit makes it likely that certain records are needed. A legal hold overrides the retention schedule: no record covered by the hold may be deleted, altered or archived beyond reach, even if its retention period has ended, until the General Counsel releases the hold in writing.

When a hold is issued:

1 Data custodians must suspend automated deletion for the named systems, mailboxes and repositories within 1 business day.
2 Data owners must confirm in writing that they have complied.
3 New records created after the hold date that match the scope are also covered.
4 The Legal team keeps a register of active holds and reviews it every quarter.
5 When the hold is released, normal retention resumes, and any record whose period had already ended is destroyed within 30 days.

Employees must never destroy documents to avoid an investigation. Doing so is a serious disciplinary matter.

8. Destruction and Disposal

1 Data is destroyed by certified methods suitable for the medium: cryptographic erase or secure overwrite for electronic storage, and cross-cut shredding or pulping for paper.
2 Hardware is disposed of only through a certified e-waste vendor that supplies a data-wipe certificate.
3 Every destruction of Confidential or Restricted data produces a destruction record, kept for 8 years, stating what was destroyed, when, how and who approved it.
4 Backups that contain expired data are overwritten as part of the normal backup rotation described in ENG-014, and data restored from a backup after deletion must be deleted again at once.
5 Test and development copies of data must be destroyed when the testing ends, and no later than 30 days afterwards.

9. Exceptions

- A business unit that needs longer retention than the schedule, for example for a long-running customer dispute, must raise the request in NorthDesk. The data owner and the General Counsel approve it, and the CISO is informed.
- A request to shorten retention is allowed only when it is not prohibited by law or contract, and needs the General Counsel's approval.
- A temporary exception for a handling control, such as sharing a Confidential file with a partner without an NDA signed yet, is not allowed. Data may be shared only after the NDA is signed.
- Exceptions to the Restricted rules (personal email, external AI tools, unencrypted storage) are never granted.
- Disputed classification decisions are resolved by the CISO after consultation with the data owner.

10. Frequently Asked Questions

- Can I paste a customer's error log into an external AI tool? No. Customer production data is Restricted and must never go into external AI tools.
- How long do we keep support tickets? 5 years after closure.
- How long do we keep email? 3 years.
- Does a legal hold stop deletion even when the retention period is over? Yes. A legal hold overrides retention.
- Which class is an employee's bank account number? Restricted, because it is personal data of an employee.
- How long do we keep CCTV recordings? 30 days.

11. Related Documents

See SEC-014 for further data-protection procedures and SEC-008 for related data handling in vendor engagements. Customer data handling in the product is covered in ENG-009 and customer-facing data practices in CS-007. Backup retention is set in ENG-014.

12. Revision History

Version	Date	Change
2.0	2024-12-02	Introduced the four-level scheme
2.5	2025-08-11	Expanded the retention schedule and legal hold section
3.0	2026-02-06	Added AI tool restrictions, destruction records and worked examples